FALSE POSITIVE, FALSE NEGATIVE И ТОЧНОСТЬ

Как объяснять срабатывания EH/Unwind Analyzer на защите

Документ объясняет TP, FP, TN, FN, precision, recall, accuracy, ground truth и то, почему проект не является ML-моделью, хотя эти термины применимы к его оценке качества.

Главный ответ комиссии
Внутри проекта нет машинного обучения и нет обучаемой модели. Анализатор работает по правилам и эвристикам. Поэтому TP/FP/TN/FN используются не как часть работы алгоритма, а как язык оценки качества на размеченном корпусе: сравниваются ожидаемые нарушения и фактические findings отчета.

1. Есть ли это в проекте

В текущем коде EH/Unwind Analyzer нет ML-классификатора, обучения, feature vectors в ML-смысле, training set, loss function и автоматического расчета confusion matrix. Проект использует детерминированные проверки и эвристические правила: если нарушен структурный или контекстный инвариант, создается finding.

Тем не менее термины true positive, false positive, true negative и false negative применимы к проекту при внешней оценке качества. Для этого нужен размеченный corpus: для каждого файла, записи или признака заранее известно, должно ли нарушение считаться присутствующим. Потом результат анализатора сравнивается с этой эталонной разметкой.

Что	Внутри проекта сейчас	Как использовать на защите
ML-модель	Нет	Говорить честно: это rule-based/static+dynamic analyzer, а не нейросетевая модель.
27 признаков	Да	Это набор диагностических правил, а не обученные веса модели.
Score/confidence	Да	Эвристическая оценка силы evidence, не ML probability.
TP/FP/TN/FN	Не считаются автоматически как runtime-метрика	Их можно считать при экспериментальной оценке на размеченном корпусе.
Accuracy/precision/recall	Не являются встроенным итогом продукта	Их можно получить только после строгой разметки positive/negative samples.

2. Базовые термины

Термин	Перевод	Смысл для проекта
Ground truth	Эталонная разметка	Заранее установленная истина: какое нарушение есть в файле, где оно находится и почему оно считается нарушением.
Positive	Положительный класс	Случай, где нарушение или интересующий finding действительно должен быть обнаружен.
Negative	Отрицательный класс	Случай, где нарушения данного типа нет и finding появляться не должен.
Signal / finding	Срабатывание / диагностический вывод	То, что analyzer записал в отчет: например unwind_parse_fail или rf_overlaps.
Threshold	Порог решения	Граница, после которой score или набор признаков считается достаточным для тревожного вывода.

Без ground truth нельзя честно говорить “false positive” или “false negative”. Если эксперт не знает, было ли нарушение на самом деле, можно говорить только “finding требует проверки” или “подозрительный сигнал”, но не вычислять точность.

3. Confusion matrix

Confusion matrix - это таблица четырех вариантов результата для бинарного решения. В нашем проекте бинарным решением может быть не “вредоносный файл или нет”, а более узкий вопрос: например, должен ли сработать конкретный finding code для конкретного PE.

Ground truth / результат	Analyzer дал сигнал	Analyzer не дал сигнал
Нарушение есть	TP: true positive. Правильное обнаружение.	FN: false negative. Нарушение пропущено.
Нарушения нет	FP: false positive. Ложное срабатывание.	TN: true negative. Правильное отсутствие сигнала.

4. Что такое TP, FP, TN, FN на примерах проекта

Случай	Пример для EH/Unwind Analyzer	Как объяснять
TP	В тестовом PE действительно пересекаются RUNTIME_FUNCTION ranges, и отчет содержит rf_overlaps.	Инструмент правильно обнаружил заранее внесенное нарушение.
FP	Корректный PE нестандартного toolchain получает finding handler_dominance, хотя это нормальный central language handler.	Это ложное срабатывание; его уменьшают context rules, weakening rules и ручная проверка.
TN	Benign PE имеет обычные .pdata/.xdata, и отчет не содержит тревожных findings.	Инструмент правильно не создал лишнюю тревогу.
FN	В PE есть согласованно измененная metadata, но она не нарушает текущие 27 инвариантов, и finding не появился.	Это пропуск относительно более широкой цели; лечится расширением правил, disassembly/prolog matching и dynamic correlation.

5. Метрики качества

Метрика	Формула	Что означает
Accuracy	(TP + TN) / (TP + TN + FP + FN)	Доля всех правильных решений. Опасна при сильном дисбалансе classes.
Precision	TP / (TP + FP)	Из всех срабатываний какая доля действительно подтверждается ground truth.
Recall / sensitivity	TP / (TP + FN)	Из всех реальных нарушений какую долю инструмент нашел.
Specificity	TN / (TN + FP)	Из всех нормальных случаев какую долю инструмент не пометил ошибочно.
FPR	FP / (FP + TN)	False positive rate: доля ложных тревог среди negative cases.
FNR	FN / (FN + TP)	False negative rate: доля пропусков среди positive cases.
F1	2 * precision * recall / (precision + recall)	Баланс precision и recall, но скрывает TN и не заменяет полный анализ.

Для защиты важно: overall accuracy может выглядеть красиво, но быть бесполезной. Если corpus почти весь benign, инструмент, который всегда говорит “аномалий нет”, получит высокую accuracy, но recall по нарушениям будет нулевой. Поэтому для такого анализатора лучше говорить о per-class precision/recall по конкретным finding families.

6. Почему это не машинное обучение

В машинном обучении модель обычно обучается на dataset: получает признаки, оптимизирует параметры, затем на test set оценивается через TP/FP/TN/FN, accuracy, precision, recall. В нашем проекте нет обучения параметров. Признаки выбраны инженерно: они основаны на структуре PE x64 EH/Unwind metadata, требованиях формата, ожидаемых свойствах RUNTIME_FUNCTION/UNWIND_INFO и подозрительных сочетаниях placement/reuse/handler behavior.

Поэтому фраза “точность модели” опасна. Если комиссия спросит, нужно уточнить: “Если под моделью понимать ML-модель, ее нет. Если под моделью понимать эвристическую модель анализа, ее качество оценивается через тестовый и размеченный corpus, но глобальная statistical accuracy без репрезентативного ground truth corpus не заявляется”.

Готовый ответ
Проект не обучается и не классифицирует вредоносность как нейросеть. Он выявляет структурные и контекстные аномалии EH/Unwind metadata. Термины TP/FP/TN/FN применяются на этапе проверки качества: мы сравниваем ожидаемые findings на размеченных PE с фактическими findings отчета.

7. Какие validation signals есть сейчас

Проверка	Что показывает	Чего не доказывает
16/16 CTest	Кодовые сценарии парсера, эвристик, отчетов, CLI, fuzz и release checks проходят.	Не является статистической accuracy на мировом PE-corpus.
78 тестовых PE	Подготовленный корпус демонстрирует normal/static/dynamic/mixed cases и expected findings.	Не заменяет размеченный real-world benchmark.
Real benign corpus 106/106 valid, non-zero scores 0	На проверенном benign-наборе не наблюдались false-positive scores.	Не гарантирует отсутствие FP на всех benign PE мира.
Static labeled corpus 14/14 valid	На размеченных synthetic/labeled случаях отчеты валидны и ожидаемые сценарии проходят.	Размер corpus мал для общей статистики точности.
Mutation fuzz 120 cases	Парсер устойчив к поврежденным входам: controlled failure или valid report.	Это robustness, а не detection accuracy.

8. Как правильно строить эксперимент для TP/FP/TN/FN

- Определить unit of evaluation: file-level, record-level, finding-level или event-level.
- Задать positive class: например, “есть rf_overlaps” или “есть malformed CountOfCodes”.
- Задать negative class: корректные объекты без данного нарушения.
- Создать ground truth: synthetic samples, ручная экспертная разметка, differential parsers, compiler provenance.
- Запустить analyzer одинаковой командой и сохранить JSON/HTML evidence.
- Для каждого объекта сравнить expected finding с actual finding.
- Посчитать TP, FP, TN, FN и затем precision, recall, specificity, FPR, FNR.
- Разбирать FP и FN отдельно: это источник улучшения правил, thresholds, context mitigations и документации.

9. Как отвечать на жесткие вопросы

Какая точность проекта?

Общая статистическая accuracy не заявляется, потому что для нее нужен большой репрезентативный размеченный corpus. Есть инженерная валидация: CTest, synthetic/labeled corpus, benign corpus, dynamic corpus и mutation fuzz.

Есть ли false positives?

Возможны, как у любого эвристического анализатора. Проект снижает их через evidence, severity, confidence, context rules, weakening rules и требование ручной проверки.

Есть ли false negatives?

Возможны. Например, если вмешательство не нарушает проверяемые инварианты или код и metadata изменены согласованно. Для снижения FN нужны disassembly/prolog matching и расширение dynamic correlation.

Почему не используете нейросеть?

Потому что задача основана на формальных структурах PE/EH/Unwind. Для таких инвариантов rule-based подход объяснимее, воспроизводимее и лучше защищается evidence. ML можно использовать позже для triage, но не вместо строгого parser-а.

Можно ли считать 106/106 benign как 100% specificity?

Только на этом конкретном corpus и при выбранном threshold. Нельзя переносить это на все возможные benign PE без дополнительного benchmark.

Что значит confidence в отчете?

Это эвристическая уверенность/сила evidence в рамках правил проекта, а не ML probability и не вероятность вредоносности.

10. Итоговая формулировка для защиты

“В проекте нет машинного обучения, поэтому TP/FP/TN/FN не используются как внутренняя логика модели. Анализатор rule-based: он проверяет структурные и контекстные инварианты PE x64 EH/Unwind metadata. Но при оценке качества эти термины применимы: на размеченном corpus мы сравниваем expected findings с actual findings. True positive - нарушение было и найдено; false positive - нарушения не было, но finding появился; true negative - нарушения не было и finding не появился; false negative - нарушение было, но analyzer его пропустил. Общую accuracy я не заявляю без большого ground truth corpus; вместо этого показываю многоуровневую инженерную валидацию и объяснимые отчеты с evidence.”